

Privora

Data Dictionary

Prepared for: Bassam — Founder, Privora
April 2026 | Confidential

Privora — Data Dictionary

Overview

This document defines every table (collection) in the Privora database, with field-level descriptions, data types, constraints, and business meaning.

Database: PostgreSQL 15+ **ORM:** Sequelize 6 **ID Format:** UUID v4 for all primary keys

Table: users

Stores all platform users — both individual users and organization administrators.

Field	Type	Nullable	Description
id	UUID	No	Primary key. Auto-generated UUID v4.
email	VARCHAR(255)	No	Unique email address. Used for OTP login.
name	VARCHAR(200)	No	Full name of the user.
phone	VARCHAR(20)	Yes	Optional phone number.
nationalId	VARCHAR(255)	Yes	

Field	Type	Nullable	Description
			Encrypted Saudi National ID. Reserved for future Nafath integration.
role	ENUM	No	One of: <code>user</code> , <code>org_admin</code> , <code>super_admin</code> . Default: <code>user</code> .
organizationId	UUID	Yes	FK to organizations. Set only for <code>org_admin</code> role. Null for regular users.
passwordHash	VARCHAR(255)	Yes	bcrypt hash. Set only for admin accounts. Regular users authenticate via OTP only.
isActive	BOOLEAN	No	Whether the account is active. Default: true.
isEmailVerified	BOOLEAN	No	Whether email has been verified. Default: false.
lastLoginAt	DATE	Yes	Timestamp of the most recent successful login.
preferredLanguage	ENUM	No	<code>en</code> or <code>ar</code> . Default: <code>en</code> .
createdAt	DATE	No	Auto-set by Sequelize on record creation.
updatedAt	DATE	No	Auto-updated by Sequelize on every change.

Indexes: email, role, organizationId

Business Rules: - `org_admin` users must have a valid `organizationId` - `passwordHash` is only set for `super_admin` and `org_admin` accounts - Regular `user` accounts authenticate exclusively via OTP - Setting `isActive = false` prevents login

Table: organizations

Registered organizations using the platform.

Field	Type	Nullable	Description
id	UUID	No	Primary key.
name	VARCHAR(500)	No	Official organization name.

Field	Type	Nullable	Description
nameAr	VARCHAR(500)	Yes	Arabic name. Required for PDPL Arabic-language notices.
logoUrl	VARCHAR(1000)	Yes	URL to organization logo.
contactEmail	VARCHAR(255)	Yes	Primary contact email for the organization.
website	VARCHAR(500)	Yes	Organization website URL.
industry	VARCHAR(100)	Yes	Business sector (e.g., healthcare, finance, retail).
isActive	BOOLEAN	No	Whether the organization is active. Default: true.
pdplRegistrationNumber	VARCHAR(100)	Yes	SDAIA/PDPL registration number if available.
createdAt	DATE	No	Record creation timestamp.
updatedAt	DATE	No	Last updated timestamp.

Business Rules: - Deactivating an organization (`isActive = false`) prevents all its admins from logging in - One organization can have multiple `org_admin` users

Table: consent_requests

Consent requests created by organizations and sent to users.

Field	Type	Nullable	Description
id	UUID	No	Primary key.
organizationId	UUID	No	FK to organizations. The org that created this request.
title	VARCHAR(500)	No	Human-readable title of the consent request.
titleAr	VARCHAR(500)	Yes	Arabic title. PDPL requires Arabic-language notices.
description	TEXT	No	

Field	Type	Nullable	Description
			Plain-language explanation of what data is collected and why.
descriptionAr	TEXT	Yes	Arabic description.
dataTypes	JSONB	No	Array of data type strings. E.g. <code>["name", "email", "location", "health_data"]</code> .
purpose	VARCHAR(1000)	No	PDPL Art. 6 — specific, explicit purpose for processing.
legalBasis	ENUM	No	One of: <code>consent</code> , <code>contract</code> , <code>legal_obligation</code> , <code>vital_interests</code> , <code>public_task</code> , <code>legitimate_interests</code> . Default: <code>consent</code> .
retentionPeriod	VARCHAR(100)	Yes	Human-readable retention period. E.g. "2 years", "Until contract ends".
expiresAt	DATE	Yes	If set, the consent request auto-expires after this date.
isActive	BOOLEAN	No	Whether the request is currently active. Default: true.
targetAudience	JSONB	No	Array of specific user IDs, or empty array for all users. Default: <code>[]</code> .
privacyPolicyUrl	VARCHAR(1000)	Yes	Link to the organization's privacy policy.
createdBy	UUID	No	FK to users. The admin who created this request.
createdAt	DATE	No	Record creation timestamp.
updatedAt	DATE	No	Last updated timestamp.

Indexes: organizationId, isActive, createdBy, expiresAt

Business Rules: - `dataTypes` must contain at least one item - `purpose` must be specific and explicit (PDPL Art. 6 requirement) - `legalBasis = 'consent'` means the user's approval is the legal ground; other bases may not require explicit consent - Setting `isActive = false` hides the request from users

Table: consent_transactions

Records every user consent decision (approved, rejected, withdrawn).

Field	Type	Nullable	Description
id	UUID	No	Primary key.
consentRequestId	UUID	No	FK to consent_requests.
userId	UUID	No	FK to users. The user making the decision.
organizationId	UUID	No	FK to organizations. Denormalized for faster queries.
status	ENUM	No	One of: <code>approved</code> , <code>rejected</code> , <code>withdrawn</code> .
reason	TEXT	Yes	Optional reason for rejection or withdrawal.
ipAddress	VARCHAR(45)	Yes	IP address at time of decision. For audit trail.
userAgent	VARCHAR(500)	Yes	Browser/device information. For audit trail.
respondedAt	DATE	No	Timestamp of the consent decision.
createdAt	DATE	No	Record creation timestamp.
updatedAt	DATE	No	Last updated timestamp.

Indexes: consentRequestId, userId, organizationId, status

Business Rules: - A user can only have one active response per consent request - Approving a withdrawn consent creates a new record - Records are never deleted — withdrawal creates a new `withdrawn` record - `withdrawnAt` is tracked via `respondedAt` on the withdrawal record

Table: data_sharing_requests

Requests from organizations to share a specific user's data.

Field	Type	Nullable	Description
id	UUID	No	Primary key.
organizationId	UUID	No	FK to organizations. The org requesting the data share.

Field	Type	Nullable	Description
requestingOrgId	UUID	Yes	FK to organizations. If a second org is requesting the data (org-to-org sharing).
userId	UUID	No	FK to users. The user whose data is being requested.
title	VARCHAR(500)	No	Title describing the data sharing request.
purpose	TEXT	No	Why this data is being shared.
dataTypes	JSONB	No	Array of data types to be shared.
duration	VARCHAR(200)	No	How long the data will be used. E.g. "6 months".
purposeCategory	VARCHAR(100)	Yes	Category of purpose for classification.
legalBasis	ENUM	Yes	Legal basis for sharing.
status	ENUM	No	One of: <code>pending_consent</code> , <code>consent_approved</code> , <code>completed</code> , <code>rejected</code> , <code>expired</code> , <code>revoked</code> .
privacyNotice	TEXT	Yes	Privacy notice specific to this data share.
respondedAt	DATE	Yes	When the user responded.
expiresAt	DATE	Yes	Expiry date for the sharing permission.
createdAt	DATE	No	Record creation timestamp.
updatedAt	DATE	No	Last updated timestamp.

Indexes: organizationId, userId, status

Status Flow:

```

pending_consent → consent_approved → completed
                  → rejected
                  → expired (auto, when expiresAt passes)
                  → revoked (user or org cancels)

```

Table: data_sharing_transactions

Immutable record of each actual data sharing execution.

Field	Type	Nullable	Description
id	UUID	No	Primary key.
requestId	UUID	No	FK to data_sharing_requests.
organizationId	UUID	No	FK to organizations.
userId	UUID	No	FK to users. Whose data was shared.
dataTypes	JSONB	No	Exact data types that were shared in this transaction.
action	VARCHAR(100)	No	Action taken. E.g. <code>data_shared</code> , <code>data_access_revoked</code> .
metadata	JSONB	Yes	Additional structured data about the transaction.
createdAt	DATE	No	Transaction timestamp.

Note: This table is append-only. No updates or deletes.

Table: dsar_requests

Data Subject Access Requests — users exercising their rights under PDPL.

Field	Type	Nullable	Description
id	UUID	No	Primary key.
userId	UUID	No	FK to users. The user submitting the request.
organizationId	UUID	No	FK to organizations. The org the request is directed at.
requestType	ENUM	No	One of: <code>access</code> , <code>correction</code> , <code>deletion</code> , <code>portability</code> , <code>objection</code> .
description	TEXT	Yes	Optional explanation from the user.
status	ENUM	No	One of: <code>pending</code> , <code>in_progress</code> , <code>completed</code> , <code>rejected</code> . Default: <code>pending</code> .
slaDeadline	DATE	No	30 days from <code>createdAt</code> . PDPL compliance deadline.
daysRemaining	INTEGER	Yes	Computed: days until SLA deadline. Negative = overdue.

Field	Type	Nullable	Description
isOverdue	BOOLEAN	No	True if <code>slaDeadline < NOW()</code> and status is not completed/rejected.
adminNotes	TEXT	Yes	Internal notes from the admin processing the request. Not shown to user.
responseData	TEXT	Yes	The actual response provided to the user (e.g., data extract).
rejectionReason	TEXT	Yes	Reason if the request was rejected. Shown to user.
processedAt	DATE	Yes	When the admin completed/rejected the request.
createdAt	DATE	No	Request submission timestamp.
updatedAt	DATE	No	Last updated timestamp.

Indexes: `userId`, `organizationId`, `status`, `slaDeadline`

Request Type Definitions: - `access` — User wants a copy of all data held about them - `correction` — User wants inaccurate data corrected - `deletion` — User wants their data erased (right to be forgotten) - `portability` — User wants data in a machine-readable format - `objection` — User objects to a specific processing activity

Table: `breach_incidents`

Security breach and data incident records.

Field	Type	Nullable	Description
<code>id</code>	UUID	No	Primary key.
<code>organizationId</code>	UUID	No	FK to organizations.
<code>title</code>	VARCHAR(500)	No	Brief title of the incident.
<code>description</code>	TEXT	No	Detailed description of what happened.
<code>breachType</code>	ENUM	No	One of: <code>unauthorized_access</code> , <code>data_loss</code> , <code>ransomware</code> , <code>insider_threat</code> , <code>system_compromise</code> , <code>accidental_disclosure</code> , <code>other</code> .

Field	Type	Nullable	Description
severity	ENUM	No	One of: <code>low</code> , <code>medium</code> , <code>high</code> , <code>critical</code> . Default: <code>medium</code> .
status	ENUM	No	One of: <code>open</code> , <code>investigating</code> , <code>contained</code> , <code>resolved</code> . Default: <code>open</code> .
affectedDataTypes	JSONB	No	Array of data types affected by the breach.
estimatedAffectedUsers	INTEGER	Yes	Estimated number of users whose data was compromised.
discoveredAt	DATE	No	When the breach was discovered. Default: now.
resolvedAt	DATE	Yes	When the incident was fully resolved.
actionsTaken	TEXT	Yes	Description of remediation and containment actions.
timeline	JSONB	No	Array of timeline events. Each: <code>{timestamp, action, performedBy, note}</code> . Default: <code>[]</code> .
notifiedAuthority	BOOLEAN	No	Whether SDAIA has been notified. Default: false.
notifiedAuthorityAt	DATE	Yes	When SDAIA was notified.
notifiedUsers	BOOLEAN	No	Whether affected users have been notified. Default: false.
notifiedUsersAt	DATE	Yes	When users were notified.
authorityDeadline	DATE	Yes	72-hour deadline from <code>discoveredAt</code> for SDAIA notification (PDPL Art. 19).
isAuthorityOverdue	BOOLEAN	No	True if <code>authorityDeadline < NOW()</code> and <code>notifiedAuthority = false</code> .
reportedBy	UUID	No	FK to users. Admin who logged the incident.
createdAt	DATE	No	Record creation timestamp.
updatedAt	DATE	No	Last updated timestamp.

Indexes: organizationId, status, severity, discoveredAt

Table: retention_policies

Data retention rules per data category per organization.

Field	Type	Nullable	Description
id	UUID	No	Primary key.
organizationId	UUID	No	FK to organizations.
name	VARCHAR(200)	No	Policy name. E.g. "Customer PII Policy".
dataCategory	ENUM	No	One of: pii, sensitive, financial, biometric, behavioral, location, general.
retentionDays	INTEGER	No	Number of days data in this category should be retained. Min: 1, Max: 36500.
warningDays	INTEGER	Yes	Days before expiry to show a warning.
action	ENUM	No	What to do when data expires: delete, anonymize, alert_only. Default: alert_only.
purpose	VARCHAR(200)	Yes	Why this retention period is required.
isActive	BOOLEAN	No	Whether this policy is active. Default: true.
createdBy	UUID	No	FK to users. Admin who created the policy.
createdAt	DATE	No	Record creation timestamp.
updatedAt	DATE	No	Last updated timestamp.

Indexes: organizationId, dataCategory

Table: privacy_notices

Versioned privacy notices published by organizations.

Field	Type	Nullable	Description
id	UUID	No	Primary key.
organizationId	UUID	No	FK to organizations.
title	VARCHAR(500)	No	Notice title.
version	VARCHAR(20)	No	Version number in format <code>X.Y</code> . E.g. "1.0", "2.3".
purposeOfProcessing	TEXT	No	Main purpose for which personal data is processed.
dataTypesCollected	JSONB	Yes	Array of data types collected by the org.
retentionSummary	VARCHAR(500)	Yes	Plain-language summary of retention periods.
thirdPartySharing	BOOLEAN	No	Whether data is shared with third parties. Default: false.
thirdPartyDetails	TEXT	Yes	Details of third-party sharing if <code>thirdPartySharing = true</code> .
dataSubjectRights	JSONB	Yes	Array of rights available to users under this notice.
contactEmail	VARCHAR(255)	Yes	DPO or privacy contact email.
legalBasis	TEXT	Yes	Legal basis summary.
isActive	BOOLEAN	No	Only one notice per org should be active at a time. Default: false.
effectiveDate	DATE	Yes	When this notice came into effect.
previousVersionId	UUID	Yes	FK to <code>privacy_notices</code> . Links to the version this supersedes.
changeNotes	TEXT	Yes	Summary of what changed from the previous version.
createdBy	UUID	No	FK to users. Admin who created the notice.
createdAt	DATE	No	Record creation timestamp.
updatedAt	DATE	No	Last updated timestamp.

Indexes: organizationId, isActive, version

Business Rules: - Only one notice per organization should have `isActive = true` at any time - Activating a new notice automatically deactivates the previous one - Previous versions are preserved and queryable for audit purposes

Table: processing_purposes

Registry of all personal data processing purposes for an organization.

Field	Type	Nullable	Description
id	UUID	No	Primary key.
organizationId	UUID	No	FK to organizations.
name	VARCHAR(200)	No	Purpose name. E.g. "Customer Analytics".
description	TEXT	No	Detailed description of the processing activity.
legalBasis	VARCHAR(200)	No	Legal basis under PDPL.
dataTypes	JSONB	No	Array of data types processed for this purpose.
pdplArticle	VARCHAR(50)	Yes	Relevant PDPL article. E.g. "Art. 5", "Art. 6".
isActive	BOOLEAN	No	Whether this purpose is currently in use. Default: true.
createdBy	UUID	No	FK to users. Admin who registered the purpose.
createdAt	DATE	No	Record creation timestamp.
updatedAt	DATE	No	Last updated timestamp.

Table: audit_logs

Immutable append-only log of all significant system actions. Cannot be updated or deleted.

Field	Type	Nullable	Description
id	UUID	No	Primary key.

Field	Type	Nullable	Description
actorId	UUID	Yes	FK to users. Who performed the action. Null for system-initiated actions.
actorRole	VARCHAR(50)	Yes	Role of the actor at time of action. Denormalized for historical accuracy.
organizationId	UUID	Yes	FK to organizations. Which org the action belongs to.
action	VARCHAR(100)	No	Action code. E.g. <code>CONSENT_APPROVED</code> , <code>BREACH_LOGGED</code> , <code>DSAR_SUBMITTED</code> , <code>ADMIN_LOGIN</code> .
resourceType	VARCHAR(100)	Yes	Type of resource affected. E.g. <code>ConsentRequest</code> , <code>BreachIncident</code> .
resourceId	UUID	Yes	ID of the specific resource affected.
description	TEXT	Yes	Human-readable description of what happened.
metadata	JSONB	No	Structured additional data. Contents vary by action type. Default: <code>{}</code> .
ipAddress	VARCHAR(45)	Yes	IP address of the actor. IPv4 or IPv6.
userAgent	VARCHAR(500)	Yes	Browser or API client user agent string.
severity	ENUM	No	One of: <code>info</code> , <code>warning</code> , <code>critical</code> . Default: <code>info</code> .
createdAt	DATE	No	Timestamp of the action. Immutable.

Note: `updatedAt` is disabled for this table. `beforeUpdate` and `beforeDestroy` hooks throw errors — records cannot be modified or deleted.

Indexes: `actorId`, `organizationId`, `action`, (`resourceType` + `resourceId`), `createdAt`, `severity`

Common Action Codes:

Action	Severity	Triggered By
ADMIN_LOGIN	info	Admin successful login

Action	Severity	Triggered By
USER_LOGIN	info	User successful login
LOGIN_FAILED	warning	Failed OTP verification
CONSENT_REQUEST_CREATED	info	Org admin creates consent request
CONSENT_APPROVED	info	User approves consent
CONSENT_REJECTED	info	User rejects consent
CONSENT_WITHDRAWN	warning	User withdraws consent
DATA_SHARING_REQUESTED	info	Org creates data sharing request
DATA_SHARING_APPROVED	info	User approves data share
DATA_SHARING_REJECTED	info	User rejects data share
DATA_SHARING_EXECUTED	info	Org executes data sharing
DSAR_SUBMITTED	info	User submits DSAR
DSAR_PROCESSED	info	Admin processes DSAR
BREACH_LOGGED	critical	Org logs breach incident
BREACH_AUTHORITY_NOTIFIED	warning	SDAIA notification recorded
RETENTION_CHECK_RUN	info	Retention check executed

Table: refresh_tokens

Stores issued refresh tokens for session management.

Field	Type	Nullable	Description
id	UUID	No	Primary key.
userId	UUID	No	FK to users. Owner of this token.
tokenHash	VARCHAR(255)	No	bcrypt hash of the refresh token. Never stored in plain text.
expiresAt	DATE	No	When this token expires (typically 7 days from issuance).
isRevoked	BOOLEAN	No	Whether this token has been revoked. Default: false.
ipAddress	VARCHAR(45)	Yes	IP from which the token was issued.
userAgent	VARCHAR(500)	Yes	Device information at time of issuance.

Field	Type	Nullable	Description
createdAt	DATE	No	Token issuance timestamp.

Indexes: userId, tokenHash, expiresAt

Cleanup: Expired and revoked tokens should be purged periodically:

```
DELETE FROM refresh_tokens WHERE expires_at < NOW() OR
is_revoked = true;
```

Relationships Summary

```
organizations
├── users (organizationId)
├── consent_requests (organizationId)
├── data_sharing_requests (organizationId)
├── dsar_requests (organizationId)
├── breach_incidents (organizationId)
├── retention_policies (organizationId)
├── privacy_notices (organizationId)
├── processing_purposes (organizationId)
└── audit_logs (organizationId)

users
├── consent_transactions (userId)
├── data_sharing_requests (userId – target user)
├── dsar_requests (userId)
└── refresh_tokens (userId)

consent_requests
└── consent_transactions (consentRequestId)

data_sharing_requests
└── data_sharing_transactions (requestId)
```